Bài 3. Bitcoin Script và mật khẩu

Đề bài. ***Problem 3. Bitcoin script.*** *Alice is on a backpacking trip and is worried about her devices containing private keys getting stolen. She wants to store her bitcoins in such a way that they can be redeemed via knowledge of a password P. Accordingly, she stores them in the following ScriptPubKey address:*

```
OP_SHA256
<0xeb271cbcc2340d0b0e6212903e29f22e578ff69b>
OP_EQUAL
```

a. *Write a ScriptSig script that will successfully redeem this UTXO given the password P. Hint: it should only be one line long.*

b. *Suppose Alice chooses a six character password P. Explain why her bitcoins can be stolen soon after her UTXO is posted to the blockchain. You may assume that computing SHA256 of all six character passwords can be done in reasonable time.*

c. *Suppose Alice chooses a strong 30 character passphrase P. Is the ScriptPubKey above a secure way to protect her bitcoins? Why or why not? Hint: reason through what happens when she tries to redeem her bitcoins.*

Bài làm

a) ScriptSig và vị trí trong giao dịch

```
<P> OP_SHA256 <h> OP_EQUAL
```

Trong đó $h = SHA256(P)$. Nhưng đoạn này **chỉ thể hiện điều kiện chi tiêu**, chưa phải toàn bộ transaction.
Hai đoạn mã thực ra nằm ở **hai giao dịch khác nhau**:

```
Giao dịch trước — tạo khoản tiền cho Alice
└─ Output:
   ├─ Số bitcoin
   └─ ScriptPubKey: OP_SHA256 <h> OP_EQUAL

Giao dịch mới — Alice sử dụng khoản tiền đó
├─ Input:
│  ├─ Tham chiếu output trên bằng txid và chỉ số output
│  └─ ScriptSig: <P>
└─ Output:
   ├─ Số bitcoin muốn chuyển
   └─ Điều kiện khóa của người nhận
```

Khi kiểm tra **giao dịch mới**, node lấy `<P>` từ input, rồi kiểm tra nó theo `ScriptPubKey` của output cũ:

```
<P> → SHA256(P) → so sánh với h → TRUE
```

b) Mật khẩu sáu ký tự

Digest đã công khai trong output. Kẻ tấn công có thể duyệt ngoại tuyến toàn bộ không gian mật khẩu sáu ký tự, băm từng ứng viên và so sánh với digest. Khi tìm được P, họ tự tạo giao dịch tiêu UTXO về địa chỉ của mình. SHA256 được thiết kế để tính nhanh nên không thay thế một hàm password hashing có salt và có chi phí tính toán cao.

c) Passphrase mạnh 30 ký tự

Passphrase mạnh ngăn được vét cạn trước khi Alice tiêu coin, nhưng hashlock đơn lẻ vẫn không an toàn:

1. Alice phát giao dịch; P xuất hiện công khai trong ScriptSig.
2. Nút mạng hoặc miner đọc P từ mempool.
3. Họ tạo giao dịch cạnh tranh dùng cùng P, chuyển coin về địa chỉ của họ và có thể đặt phí cao hơn.
4. Script không có chữ ký ràng buộc người nhận hoặc nội dung giao dịch, nên giao dịch thay thế cũng hợp lệ.

Do đó, cần kết hợp hashlock với điều kiện chữ ký như `OP_CHECKSIG`.